

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this lecture, you will be able to explain what auditability means in a cloud context and distinguish it from general compliance certification review.
- By the end of this lecture, you will be able to analyse the scope limitations of SOC 2 and ISO 27001 certifications and articulate why they cannot substitute for a contractual right to audit.
- By the end of this lecture, you will be able to evaluate cloud provider sub-processor arrangements and describe how GDPR and similar frameworks extend the shared responsibility chain.
- By the end of this lecture, you will be able to design a recurring shared-considerations review programme that keeps governance current as cloud services evolve.
- By the end of this lecture, you will be able to assess maintenance and versioning practices for their security implications and identify how provider-initiated changes can invalidate existing controls.
- By the end of this lecture, you will be able to construct customer-side auditability requirements covering logging configuration, log integrity, and access accountability within a cloud governance programme.

Introduction

The second half of cloud shared considerations moves from the question of whether a service can meet your needs to the question of whether you can verify that it actually does. Auditability, governance, SLAs, sub-processor transparency, and maintenance practices are the mechanisms through which verification happens. Without them, every security commitment a provider makes is, in practice, taken on trust, and trust that cannot be validated is not a defensible security control.

A recurring theme in real cloud security failures is that organisations assumed they had protections they had never actually confirmed. A SOC 2 report was accepted without checking whether the organisation's workloads fell within its scope. A right-to-audit clause was missing from the contract because procurement did not treat it as a negotiation priority. A sub-processor updated its data processing practices and nobody noticed because there was no review cycle. The shared considerations in this lecture are the governance mechanisms that prevent these gaps from opening silently over time.

Cloud services are not static. Providers update APIs, deprecate features, revise SLA terms, and change their sub-processor lists. An evaluation that was thorough three years ago may be materially out of date today. Treating shared-considerations review as a one-time procurement activity is itself a governance failure. This lecture makes the case for building a continuous review programme and provides the conceptual tools to sustain it.

Core Concepts Explained

Auditability and the Right to Audit

Definition: Auditability is the ability to independently verify that a cloud provider is meeting its stated security, compliance, and contractual commitments. The right to audit is a contractual clause that formalises the customer's entitlement to conduct or commission that verification.

Business relevance: Organisations subject to financial, healthcare, or public-sector regulations must be able to demonstrate to their own auditors that the third parties handling their data are operating securely. Without auditability provisions, demonstrating this to regulators becomes impossible and exposes the organisation to compliance enforcement action.

Cloud Security Practitioner relevance: As a Cloud Security Practitioner, you are responsible for ensuring that audit provisions are included in cloud contracts before service commencement, that the scope of those provisions is sufficient for your regulatory obligations, and that audit rights are exercised at appropriate intervals throughout the relationship.

Real-world example: A healthcare insurer migrating claims processing to a cloud provider discovered during contract review that the standard agreement contained no right-to-audit clause, only a commitment to share existing third-party audit reports. The insurer's HIPAA compliance programme required annual independent assessment of business associates' security controls. The legal and security teams jointly negotiated a clause permitting annual audits by the insurer's designated assessor, with the provider given thirty days' notice. When the first audit revealed that encryption at rest was not applied to a staging environment containing de-identified claims data, the insurer was able to require remediation under the contract. Without the audit clause, the gap would have had no mechanism for discovery or remediation.

Risks or limitations: Without a right-to-audit clause, customers have no contractual basis to verify provider security controls beyond whatever the provider chooses to disclose. The best practice that prevents this exposure is requiring and negotiating explicit audit rights during procurement, before the contract is signed, and treating the absence of audit provisions as a disqualifying condition for sensitive workloads.

SOC Reports and ISO 27001: Scope and Limitations

Definition: SOC (System and Organization Controls) reports and ISO 27001 certifications are third-party assurance mechanisms that cover a defined scope, a defined time period, and a defined set of controls. They do not guarantee that controls outside their scope are adequate or that the specific workloads a customer runs fall within the audited boundary.

Business relevance: Provider certifications are frequently used as procurement shorthand for a secure provider. They provide genuine assurance within their limits, but misunderstanding those limits leads organisations to assume protections that do not exist for their specific context.

Cloud Security Practitioner relevance: A Cloud Security Practitioner must read provider compliance documentation critically: identify the scope boundary, the audit period, and the specific control objectives tested. If the customer's workload is not within the audit scope, the certification provides no direct assurance about that workload.

Real-world example: A global logistics company migrated its customs documentation platform to a cloud provider holding a SOC 2 Type II report and ISO 27001 certification. The security team accepted these certifications without reviewing the scope appendices. Eighteen months later, an internal audit revealed that the data centre hosting their European workloads had been excluded from the SOC 2 scope because it was managed by a regional sub-contractor outside the primary certification boundary. The certifications they had

relied upon did not cover the infrastructure actually processing their data. Reading the scope appendices and verifying that the customer's specific services and regions fell within the audit boundary would have identified this gap before the contract was signed.

Risks or limitations: Relying on provider certifications without reviewing their scope boundaries creates a false sense of assurance. The practice that prevents this is systematic scope mapping: for each certification the provider holds, documenting which services, regions, and control domains it covers and verifying alignment with the customer's workload footprint before accepting the certification as sufficient evidence.

Sub-Processors and the Extended Accountability Chain

Definition: Sub-processors are vendors that a primary cloud provider uses to process customer data on the provider's behalf. Under frameworks such as GDPR, the customer must be informed of sub-processors and the contractual protections for personal data must flow through the entire chain.

Business relevance: Major cloud providers routinely use sub-processors for support, storage, analytics, and content delivery. Customer data may be processed by dozens of sub-contractors the customer has never directly evaluated. A breach or compliance failure at any point in the chain creates liability exposure for the customer as well as the primary provider.

Cloud Security Practitioner relevance: Cloud Security Practitioners must review provider sub-processor lists during procurement, require notification of changes, and map sub-processor data flows against applicable regulatory requirements. Where a sub-processor's data processing arrangement is inadequate, the gap must be resolved before the contract is signed.

Real-world example: A European e-commerce company engaged a cloud-based analytics provider to process customer behaviour data. During a GDPR readiness review, the security team requested the provider's sub-processor list. It revealed that a third-party data enrichment firm in the United States had access to European customer data for analytics processing. This transfer was subject to GDPR Chapter V requirements on international data transfers, which the original data processing agreement had not addressed. The company required Standard Contractual Clauses for that sub-processor relationship before go-live. Had the sub-processor list not been reviewed, the company would have been processing European personal data under a non-compliant international transfer arrangement from day one.

Risks or limitations: Failing to review and track sub-processor arrangements creates regulatory exposure and extends the attack surface to vendors the customer has never assessed. The practice that prevents this is requiring sub-processor change notification rights in the contract and building regular review of those notifications into the cloud governance programme.

Maintenance, Versioning, and Security Control Drift

Definition: Cloud providers continuously update platforms, deprecate old features, and introduce new ones. Versioning refers to the provider's management of these changes, including communication practices, deprecation timelines, and the customer's ability to pin workloads to specific versions. Provider-initiated changes can alter the behaviour of existing security controls without the customer's knowledge.

Business relevance: A security control validated at deployment may behave differently after a provider update. Authentication mechanisms, encryption defaults, API behaviour, and logging output can all change with platform updates. If the customer is not tracking these changes, their security posture can degrade silently over weeks or months before the drift is detected.

Cloud Security Practitioner relevance: Cloud Security Practitioners must subscribe to provider change notification channels, maintain a log of security-relevant platform changes, and build a process for re-validating security controls after significant provider updates are applied.

Real-world example: A financial services firm relied on a cloud provider's native encryption-at-rest feature for its managed database service. The provider released a platform update that changed the default encryption key management behaviour, shifting from provider-managed keys to a model where the customer was expected to configure their own key management service. The change notification appeared in the provider's technical changelog ninety days before the update. Because the firm had no process for monitoring that channel, the update was not noticed until a routine compliance scan flagged that encryption keys were no longer rotating on schedule. The interim period represented undetected configuration drift. Assigning ownership of provider change notification monitoring and scheduling quarterly reviews would have caught this during the ninety-day notice window.

Risks or limitations: Without a systematic process for tracking provider platform changes, security controls can be invalidated by updates the customer was never aware of. The practice that prevents this is a formal cloud change management process that routes security-relevant provider notifications to the security team for assessment before the change takes effect.

Customer-Side Auditability: Logging, Integrity, and Access Accountability

Definition: Customer-side auditability refers to the customer's own ability to account for activity within their cloud environment: who accessed what, when, what was changed, and what was running. It depends on correctly configuring provider logging mechanisms, storing logs in a tamper-evident manner, and establishing a regular review cadence.

Business relevance: Regulatory frameworks and security incident response both require the ability to reconstruct a timeline of events. If cloud logs are incomplete, misconfigured, or stored in a way that permits tampering, the customer cannot demonstrate compliance to auditors or conduct a reliable forensic investigation after an incident.

Cloud Security Practitioner relevance: Cloud Security Practitioners are responsible for defining logging requirements, configuring provider-native logging services such as CloudTrail or Azure Monitor, routing logs to an immutable storage tier, and establishing alerting and review processes that make the logs operationally useful rather than merely archived.

Real-world example: A technology company experienced an insider threat incident in which a departing employee with elevated cloud access exfiltrated a large dataset over their final two weeks of employment. When the incident response team attempted to reconstruct the timeline, they found that audit logging had been enabled only for production environments. The data warehouse the employee accessed was classified as non-production for cost optimisation purposes, and its logs were absent. The investigation was materially hampered and the full scope of the exfiltration could not be determined. A logging coverage policy applying consistently to all environment tiers, with logs centralised in a tamper-evident service, would have provided a complete audit trail regardless of environment classification.

Risks or limitations: Gaps in logging coverage, logs stored in mutable environments, and logs that are never reviewed create forensic blind spots and compliance exposure. The practice that prevents this is a documented logging standard specifying which services, regions, and environment tiers must generate logs, what retention periods apply, how logs are protected from tampering, and who reviews them on what schedule.

Practical Applications

The shared considerations covered in this lecture translate directly into three professional practice areas: contract negotiation and vendor evaluation, ongoing governance programme management, and incident response readiness.

Negotiating Audit Rights During Cloud Procurement

When a healthcare organisation's cloud security architect joined a vendor evaluation for a new patient records management platform, the provider's standard contract offered only access to existing SOC 2 Type II reports. The architect worked with the legal team to propose a revised clause: the right to conduct an annual security assessment through a designated third-party auditor, with the provider given thirty days' notice; updated SOC 2 reports delivered within thirty days of issuance; and security incident notification within seventy-two hours. The provider accepted the reporting and notification terms but required third-party assessments to be limited to interview and documentation review rather than direct infrastructure access, which was standard practice for large multi-tenant providers. The architect documented this limitation in the risk register and designed the annual third-party assessment scope to extract maximum assurance within those constraints, focusing on control design review, evidence sampling, and personnel interviews. The result was a contract providing substantially stronger audit provisions than the default, with limitations explicitly acknowledged and managed.

Building a Sub-Processor Review Into Cloud Governance

A financial services firm's cloud governance committee formalised its sub-processor management approach after GDPR enforcement actions in their sector raised awareness of the liability chain. The cloud security team established a two-stage process. During onboarding of any new cloud service, the sub-processor list was reviewed jointly by legal and security. Each sub-processor was assessed for jurisdiction, function, and data access scope, and any sub-processor handling personal data in a jurisdiction without an EU adequacy decision required either Standard Contractual Clauses or Binding Corporate Rules to be confirmed before go-live. Ongoing, all existing providers were required to notify sub-processor changes at least thirty days in advance. Notifications were routed to the governance committee for review and acceptance before the change took effect. When one major provider added a sub-processor in a new jurisdiction six months post-onboarding, the notification allowed the security team to confirm the required transfer mechanisms were in place and update the data processing inventory before the next regulatory reporting cycle.

Implementing a Continuous Shared-Considerations Review Programme

A retail organisation completed a thorough cloud shared-considerations evaluation during its initial migration. Two years later, a routine re-certification exercise revealed that several material conditions had changed without the organisation's knowledge: one provider had revised its data retention policy, extending the period for which transactional logs were accessible to provider support staff; a second provider had updated its SLA to remove an uptime credit provision the organisation had negotiated; and a third provider's ISO 27001 certification had been renewed with a narrowed scope that excluded the region hosting the organisation's disaster recovery environment. None of these changes had reached the security or legal team through the standard provider notification channels the organisation had been monitoring inconsistently. Following this discovery, the organisation built a formal quarterly review cycle into its cloud governance programme: SLA terms compared against the originally negotiated version, sub-processor lists compared quarter-over-quarter, certification documents re-scoped against the current workload footprint, and provider change notification channels assigned to a named owner. The programme transformed shared-considerations assessment from a point-in-time activity into an ongoing governance control.

Best Practices

- **Negotiate the right to audit before signing any cloud contract covering sensitive data.** The right to audit is substantially easier to obtain before a contract is signed than after. Require audit provisions as a non-

negotiable term for any cloud service processing personal data, financial records, or business-critical workloads. Document what the right covers: whether it permits direct assessment or only review of third-party reports, the notice period, the frequency, and the scope. Where direct audit access is not available from the provider, ensure that substitute mechanisms such as detailed questionnaire responses, updated third-party reports, and incident notification requirements are specified with enforceable timeframes rather than vague commitments.

- **Read and scope-map provider compliance certifications before accepting them as assurance evidence.** Obtain the full certification documentation including scope appendices, not just the summary or marketing collateral. Identify the services, geographic regions, and control domains explicitly included in the scope. Map that scope against your actual workload footprint. If your workloads are not within the certified scope, treat the certification as providing no direct assurance for those workloads and document the gap formally. Build this scope-mapping step into the vendor evaluation process as a standard checklist item, and repeat it annually when certifications are renewed.
- **Require sub-processor change notification rights in all cloud data processing agreements.** Many providers offer sub-processor notification as a standard contractual term, but it is not always the default. Require that the provider notify you of sub-processor additions or changes at least thirty days before the change takes effect. Maintain a register of approved sub-processors for each cloud service and treat unapproved changes as a contract matter requiring escalation. Where a change introduces a new cross-border transfer that your regulatory framework requires specific mechanisms for, resolve the mechanism requirement before accepting the change.
- **Subscribe to and operationally monitor provider security change notification channels.** Assign a named owner within the security team for each significant provider relationship, with explicit responsibility for monitoring technical changelogs, security bulletins, and deprecation notices. Build a lightweight assessment process for each notified change: does this change affect any security control currently relied upon? If yes, what re-validation or reconfiguration is required, and by when? This transforms provider change notifications from background technical information into actionable inputs to the security controls management process.
- **Define and enforce a cloud logging standard that applies consistently to all environment tiers.** Logging gaps most commonly appear in non-production, staging, or development environments that are treated as lower-priority for cost reasons. Insider threats, lateral movement, and compliance-relevant data access can all occur in these environments. Establish a logging standard specifying minimum requirements for each environment tier, with logs centralised in an immutable or WORM-protected logging service, retention periods aligned to regulatory obligations, and a designated reviewer responsible for scheduled log review. Audit compliance with the standard through automated checks rather than relying on human memory at provisioning time.

Common Mistakes and Misconceptions

Misconception: Accepting a provider's SOC 2 or ISO 27001 certification as complete assurance without reviewing the audit scope to confirm that the customer's specific workloads and regions are covered.

Correct approach: Read the full certification documentation, identify the exact scope boundary, and map it against your workload footprint. If there are gaps, require additional assurance evidence for out-of-scope components or document and accept the residual risk with explicit senior approval.

Misconception: Treating cloud shared-considerations evaluation as a one-time procurement activity completed at contract signing, with no subsequent review as the service and the customer's requirements evolve.

Correct approach: Build a recurring review cycle into cloud governance, at minimum annually, that reassesses SLA terms, sub-processor lists, certification scopes, and provider platform changes against current requirements. Assign ownership for each review activity and treat the output as a formal governance artefact retained for audit.

Misconception: Configuring cloud audit logging only in production environments, leaving staging, development, and data warehouse environments unlogged on the assumption that sensitive data or privileged access does not flow through them.

Correct approach: Define a logging coverage policy that applies to all environment tiers where regulated data, credentials, or business-critical configuration may reside. Enforce the policy through automated compliance checks that run at environment provisioning and on a scheduled basis.

Misconception: Assuming a right to audit is included in a provider's standard contract without reading the specific clause, resulting in a contract that provides only access to existing reports rather than entitlement to commission independent assessment.

Correct approach: Require legal review of the specific audit clause language before contract signature. Confirm precisely what the clause permits, the notice period, frequency, and whether the customer or a designated third party may conduct the assessment, and negotiate terms that meet your regulatory and governance requirements.

checklist: Cloud Shared-Considerations Quarterly Review Checklist

This checklist supports the quarterly review of cloud shared considerations for each significant provider relationship. Complete it for every cloud service in scope and retain the completed version as a governance artefact.

- ☐ SLA terms: download the current published SLA and compare it against the version reviewed at contract signature or last review cycle. Flag any changes to availability targets, credit provisions, incident response timelines, or exclusions for follow-up with the provider.
- ☐ Audit rights: confirm the right-to-audit clause in the current contract matches the version negotiated at signature. Verify the most recent audit under this clause was completed within the required period and that findings and remediation were documented.
- ☐ Certification scope: download the provider's current SOC 2, ISO 27001, or equivalent certification documents. Confirm the services and regions hosting your workloads remain within the certified scope. Note any scope reductions since the prior review and assess the impact on your assurance posture.
- ☐ Sub-processor list: request or download the provider's current sub-processor list. Compare it against the list from the prior review. For any additions, confirm the applicable data transfer mechanisms are in place and update the data processing inventory.
- ☐ Platform change log: review provider technical changelogs and security bulletins for the quarter. Identify changes affecting security controls, authentication, encryption defaults, logging behaviour, or API contracts. Document required responses and assign owners.
- ☐ Logging coverage: run an automated compliance check against your cloud logging standard. Confirm all in-scope environment tiers are generating logs, forwarding them to the centralised logging service, and that retention settings meet regulatory requirements.

- ☐ Log review: confirm the assigned reviewer has completed the scheduled log review for the period. Document anomalies identified and their disposition.
- ☐ Maintenance and deprecation notices: review deprecation notices issued during the quarter. Identify workloads or controls affected by upcoming changes and confirm remediation plans are in place with target completion dates.

How to use this: Retain completed checklists as evidence for internal audit and regulatory inspection. Any checklist item identifying a gap should generate a formal remediation record in the governance register with an assigned owner and target resolution date.

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. An organisation relies on a cloud provider's SOC 2 Type II report as its primary assurance evidence for a payroll processing workload. During a regulatory audit, the organisation cannot demonstrate that its payroll environment is covered by the SOC 2 scope. What should the cloud security practitioner have done during procurement?

- A) A. Requested that the provider obtain a new SOC 2 audit specifically for the payroll workload before contract signature.
- B) B. Mapped the payroll workload's services and regions against the specific scope boundary documented in the SOC 2 report to confirm coverage.
- C) C. Treated the SOC 2 report as sufficient assurance because it was issued by an independent third-party auditor.
- D) D. Required the provider to make the payroll environment available for direct on-site physical inspection before go-live.

Answer: B. Mapped the payroll workload's services and regions against the specific scope boundary documented in the SOC 2 report to confirm coverage.

Q2. Under GDPR, a cloud provider adds a new sub-processor in a non-EU country without providing the contractually required thirty days' prior notice. What is the most appropriate immediate action for the cloud security practitioner?

- A) A. Accept the change because the sub-processor is used only for support functions and is unlikely to directly access personal data.
- B) B. Escalate the contract breach to legal counsel and assess whether the cross-border transfer meets GDPR Chapter V transfer mechanism requirements.
- C) C. Update the data processing inventory to include the new sub-processor and continue operations without further action.
- D) D. Immediately suspend the cloud service until the sub-processor is removed from the provider's supply chain.

Answer: B. Escalate the contract breach to legal counsel and assess whether the cross-border transfer meets GDPR Chapter V transfer mechanism requirements.

Q3. A cloud provider issues a security bulletin stating that default encryption key management for its managed database service will change in sixty days. The security team has no process for monitoring provider bulletins. What is the most likely security outcome if no action is taken before the change occurs?

- A) A. The encryption configuration will remain unchanged because the provider cannot modify customer security settings without explicit customer authorisation.
- B) B. The database service will stop operating until the customer manually configures a replacement key management service.
- C) C. Encryption at rest may fail or revert to a weaker default, creating a control gap that existing internal monitoring systems would not automatically detect.
- D) D. The provider will automatically configure the customer's key management service using the most secure available settings.

Answer: C. Encryption at rest may fail or revert to a weaker default, creating a control gap that existing internal monitoring systems would not automatically detect.

Q4. A cloud security practitioner is reviewing a new contract for a service processing regulated financial data. The audit clause states only that the customer may request copies of the provider's most recent SOC 2 report. What is the most significant assurance gap in this clause?

- A) A. The clause does not specify a deadline for delivering the requested SOC 2 report.
- B) B. The clause does not entitle the customer to commission independent assessment of controls not covered by the existing SOC 2 scope.
- C) C. The clause does not require the provider to maintain SOC 2 certification continuously throughout the contract period.
- D) D. The clause does not specify which version of the SOC 2 framework the report must follow.

Answer: B. The clause does not entitle the customer to commission independent assessment of controls not covered by the existing SOC 2 scope.

Q5. An insider threat investigation reveals that an employee exfiltrated data from a cloud-hosted data warehouse classified as non-production. Audit logs for this environment were not enabled. Which governance control would most directly have prevented this forensic gap?

- A) A. A data loss prevention tool configured to block large downloads from the data warehouse.
- B) B. A cloud logging standard defining minimum logging requirements for all environment tiers, enforced through automated compliance checks.
- C) C. A quarterly access review that would have removed the employee's elevated permissions before the exfiltration period.
- D) D. Multi-factor authentication enforcement for all cloud console and service access.

Answer: B. A cloud logging standard defining minimum logging requirements for all environment tiers, enforced through automated compliance checks.

Reflection Questions

1. Consider a cloud service your organisation currently relies on. When was the SOC 2 or equivalent certification last reviewed against your workload footprint? Has the certified scope changed since you last checked?

2. What process does your organisation have for receiving and acting on provider change notifications? Who owns that process, and when was it last tested against an actual provider security bulletin?
3. If you had to produce a complete audit trail of all privileged access to your cloud environment for the past ninety days, how confident are you that the logs exist, are complete, and are stored in a tamper-evident location?
4. How many sub-processors does your most critical cloud provider currently use? Do you know which of them handle personal data, in which jurisdictions, and under what transfer mechanisms?
5. When was your organisation's primary cloud contract last reviewed for changes to the audit clause or SLA terms? Would you know if the provider had unilaterally revised those terms in a renewal cycle?
6. What would trigger a re-evaluation of your cloud shared considerations today: a provider notification, a regulatory change, a security incident, or only a scheduled review cycle that may be months away?

Key Takeaways

- Auditability is not an abstract commitment. It is a contractual clause that must be negotiated explicitly, before contract signature, with clear terms covering scope, frequency, notice period, and permitted assessment methods.
- SOC 2 and ISO 27001 certifications provide genuine but bounded assurance. Their value is proportional to how carefully the customer maps their scope against actual workload footprint and confirms that the audit period is current.
- GDPR and similar frameworks extend cloud accountability through the sub-processor chain. The customer must review sub-processor lists at procurement, require change notification rights, and track applicable data transfer mechanisms for cross-border personal data flows.
- Provider-initiated platform changes can silently invalidate existing security controls. Monitoring provider change channels and routing security-relevant notifications to the security team for assessment is a mandatory operational discipline, not optional governance overhead.
- Cloud logging is a customer configuration responsibility. Enabling logging only in production environments while omitting non-production tiers creates forensic blind spots that attackers and insiders can exploit and that regulators will identify during audits.
- Shared-considerations evaluation must be periodic, not one-time. SLA terms, certification scopes, sub-processor lists, and platform capabilities all change over the life of a cloud relationship. A governance programme without a scheduled re-evaluation cycle will progressively drift from the posture established at procurement.
- The right to verify, rather than the right to assume, is the foundation of trust in any cloud relationship. When independent verification is not contractually possible, that limitation is itself a risk that must be explicitly documented and managed.

Recommended Next Actions

Put this lecture to work within the next seven days:

7. Retrieve the current SOC 2 report or equivalent certification for your two most critical cloud providers and map the scope boundary against your workload inventory this week. Document any out-of-scope gaps and open remediation items for each.

8. Review the audit clause in at least one active cloud contract. Determine whether it entitles your organisation to commission independent assessment or only to receive existing reports, and note any gaps against your current regulatory requirements for follow-up at the next contract review cycle.
9. Request the current sub-processor list from each cloud provider handling personal data. Compare it against the version reviewed at procurement, identify any additions, and for each addition involving cross-border personal data transfers confirm the applicable transfer mechanism is documented and in force.
10. Run an inventory of cloud logging coverage across all environment tiers in your organisation's cloud footprint. Identify any environments where logging is not enabled or where logs are not forwarded to a centralised, tamper-evident destination, and submit a remediation request with a specific completion target date.